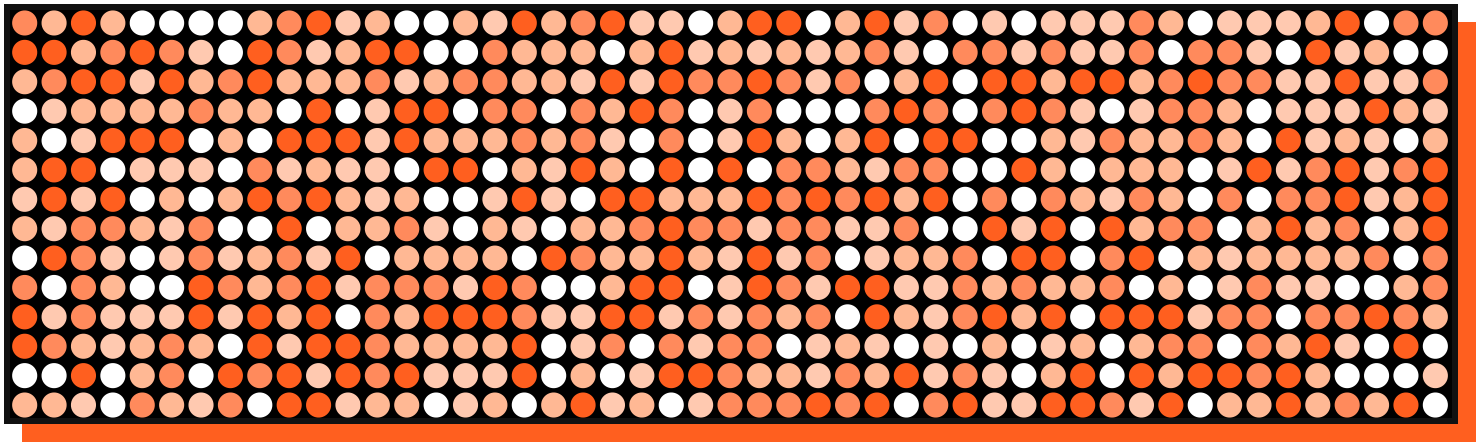
PAPYRUS EVIDENCE PACK

NIST AI RMF MAPPING

How Papyrus supports the Govern, Map, Measure and Manage functions of NIST AI 100-1, and the Generative AI Profile.



RELEASE **0.1.0+a3d9ded**	BUILT **2026-10-27T11:47:12Z**
IMAGE **ghcr.io/beaglabs/papyrus/papyrus**	INDEX DIGEST **sha256:83b1fb85aafc8c58fb481c5048f074f9e11aedbba82bbca4a1ee78bc88c91105**

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

NIST AI RMF MAPPING

How Papyrus, as the agent runtime an organization deploys, supports the organization's AI risk management. Most AI RMF outcomes are organizational; Papyrus supplies the mechanisms and records that make them practicable and evidences them. Responsibility follows the same shared model as the 800-53 matrix. Controls were reviewed against Papyrus source revision `597e13d63277`. The release image was built from `a3d9ded116d8`.

19	15	2	2
SUBCATEGORIES MAPPED	SUPPORTED	PARTIAL	CUSTOMER OWNED

Reading this mapping. The AI RMF describes outcomes for the organization that uses AI. *Supported* means Papyrus provides the mechanism and its records; *partial* items have a gap noted; *customer owned* outcomes rest with the deploying organization. The spreadsheet form, with source evidence for every row, is `papyrus-ai-rmf.xlsx`.

GOVERN

SUBCATEGORY	STATUS	PAPYRUS SUPPORT	DEPLOYING ORGANIZATION
GOVERN 1.4 Risk management process established through transparent policies and controls	SUPPORTED shared	Every named agent is a versioned configuration (instructions, model, limits, channels) signed by its creator with a one-time key certified by the deployment after a fresh sign-in. With Require agent sign-off on, a different person holding Agents.Approve must also sign before it can be activated. Only an active, signed revision runs. Evidence: `apps/server/src/agent/roster/store.ts`, `apps/server/src/agent/roster/signing.ts`	Decide when independent sign-off is required and who may approve agents.
GOVERN 1.6 Inventory of AI systems	SUPPORTED provider	The Agent Roster lists every agent with its state (draft, awaiting approval, active, paused, archived), revision history, model, signatures and sessions. Requests groups each agent's revisions with their approval status. Evidence: `apps/web/src/AgentRoster.tsx`, `apps/web/src/AgentRequests.tsx`	Review the roster as part of the organization's AI inventory.
GOVERN 1.7 Decommissioning AI systems safely	SUPPORTED provider	An agent can be paused or archived. Archiving deactivates it, so its sessions start no new runs, while its revisions, approvals and evidence are kept; a restored agent must be activated again. Evidence: `apps/server/src/agent/roster/store.ts`, `apps/server/tests/agent-roster-http.test.ts`	Archive agents that are no longer approved for use.
GOVERN 2.1 Roles, responsibilities and lines of communication documented	SUPPORTED shared	Authority is split into declared Papyrus roles (including Agents.Create, Agents.Approve, Agents.Activate, Action.Approve and Audit.View), mapped from identity-provider groups in papyrus.yaml. An agent's creator and its independent approver are recorded by identity on every revision. Evidence: `packages/contracts/src/index.ts`, `apps/server/src/agent/config-file.ts`	Assign roles in the identity provider to match the organization's AI governance structure.
GOVERN 3.2 Policies define human-AI configurations and oversight	SUPPORTED shared	Agents propose consequential actions; people approve them. Action approvals require a human with Action.Approve, workflow approval gates are answered only by the person or group they name, tool permissions decide which calls ask first, and agents can ask the person a question and wait. Evidence: `apps/server/src/agent/mastra/native-runtime.ts`, `apps/server/src/agent/mastra/workflow-runtime-tools.ts`	Set which tools and MCP servers require approval, and use approval gates in workflows that act outside Papyrus.
GOVERN 4.3 Practices for testing, incident identification and information sharing	PARTIAL shared	Security events and agent activity are recorded in an append-only audit trail and agent traces, exportable to the organization's SIEM over OTLP. **Gap:** Beag Labs has no published process for notifying customers of product security incidents. Evidence: `apps/server/src/agent/audit/otlp.ts`	Include AI incidents in the organization's incident response plan and route audit records to its SIEM.

SUBCATEGORY	STATUS	PAPYRUS SUPPORT	DEPLOYING ORGANIZATION
GOVERN 6.1 Policies address risks from third-party AI (models, data, software)	SUPPORTED shared	Models are reached only through gateways the organization lists in papyrus.yaml; the government and disconnected profiles never fall back to a commercial model endpoint. Third-party software is inventoried in SPDX and CycloneDX SBOMs, and the release image is signed with build provenance. Evidence: `apps/server/src/agent/model-store.ts`, `compliance/sbom.spdx.json`	Choose and approve model providers and models; review the SBOMs.

MAP

SUBCATEGORY	STATUS	PAPYRUS SUPPORT	DEPLOYING ORGANIZATION
MAP 1.1 Intended purposes, context and settings documented	SUPPORTED shared	Each agent revision records its name, description, instructions, model, execution profile and goal, and the signature covers exactly that configuration. Evidence: `packages/contracts/src/agents.ts`	Write each agent's purpose and constraints into its description and instructions before signing.
MAP 3.5 Processes for human oversight defined	SUPPORTED shared	Oversight is built into the run: approval gates pause workflows until a named person decides, action proposals wait for an approver, and the Inbox and notify_user bring the decision to the person. Evidence: `apps/server/src/agent/inbox.ts`, `apps/web/src/SessionWorkflowsPanel.tsx`	Define who oversees each agent and workflow.
MAP 4.1 Approaches for mapping legal risks of AI components and third-party data	CUSTOMER customer	Papyrus keeps all prompts, documents and outputs inside the deploying organization's boundary and sends nothing to Beag Labs. The legal review of models and data the organization connects is the organization's. Evidence: `apps/server/src/agent/legal/privacy.md`	Review model licenses, data rights and connected systems.

MEASURE

SUBCATEGORY	STATUS	PAPYRUS SUPPORT	DEPLOYING ORGANIZATION
MEASURE 2.4 Functionality and behavior monitored in production	SUPPORTED shared	Every agent run records its steps, tool calls, outcome and compute, and traces are kept in an observability store. Security-relevant events go to the audit trail. Evidence: `apps/server/src/agent/roster/store.ts`, `apps/web/src/Audit.tsx`	Review runs, traces and audit records on the organization's cadence.
MEASURE 2.7 Security and resilience evaluated and documented	PARTIAL shared	Agent code runs in a kernel sandbox with no network; outbound requests pass an egress allow-list; the image runs in FIPS mode and is STIG-scanned. The NIST SP 800-53 matrix in this pack documents each control with source evidence. **Gap:** No independent penetration test or adversarial (red-team) evaluation of agent behavior has been performed. Evidence: `apps/server/src/agent/egress.ts`, `apps/server/src/fips-check.ts`	Include Papyrus in the system's security assessment.
MEASURE 2.8 Transparency and accountability risks examined	SUPPORTED provider	Every agent action is attributed to the person it ran for; revisions carry verifiable signatures and the revision a session runs is shown in its header; the audit trail records who did what, from where. Evidence: `apps/server/src/agent/audit/log.ts`, `apps/server/src/agent/mcp/calls.ts`	Retain signatures and audit records for the organization's retention period.
MEASURE 2.10 Privacy risk examined	SUPPORTED shared	Papyrus runs inside the organization's environment and calls no Beag Labs service; credentials are never shown to models; secrets in configuration are references, never values. Evidence: `apps/server/src/agent/config-file.ts`	Assess privacy for the data the organization processes with agents.
MEASURE 2.11 Fairness and bias evaluated	CUSTOMER customer	Papyrus does not train or fine-tune models and does not evaluate model bias. Offline evaluations in Beag Labs CI check agent task behavior, not fairness. Evidence: `packages/evals/src/scorers.ts`	Evaluate the chosen models for the organization's use cases.

MANAGE

SUBCATEGORY	STATUS	PAPYRUS SUPPORT	DEPLOYING ORGANIZATION
MANAGE 2.2 Mechanisms to sustain the value of deployed AI	SUPPORTED provider	Each agent runs within signed limits: steps, tool calls, wall-clock time, compute time, storage and run count, enforced on every step and tool call; long-running work is handed to background tasks with their own deadlines. Evidence: `apps/server/src/agent/roster/store.ts`, `apps/server/src/agent/roster/tasks.ts`	Set limits proportionate to each agent's purpose.
MANAGE 2.4 Mechanisms to supersede, disengage or deactivate AI systems	SUPPORTED provider	An agent can be paused at once, archived, or replaced by a new signed revision; API keys can be revoked; portal sessions end on sign-out and after inactivity. Evidence: `apps/server/src/agent/roster/store.ts`, `apps/server/src/agent/portal-sessions.ts`	Use these controls in response procedures.
MANAGE 3.1 Third-party AI risks monitored and controls applied	SUPPORTED shared	Model gateways are tested before use and their configuration is recorded at each start; MCP servers are verified and their tools classified by an administrator, which decides whether calls need approval. Evidence: `apps/server/src/agent/config-audit.ts`, `apps/server/src/agent/mcp/http.ts`	Review gateway and MCP configuration changes.
MANAGE 4.1 Post-deployment monitoring plans implemented	SUPPORTED shared	Audit records stream to the organization's collector over OTLP with at-least-once delivery, and the Audit page shows export health and a backlog after outages. Evidence: `apps/server/src/agent/audit/otlp.ts`	Monitor the collector and act on alerts.

GENERATIVE AI PROFILE (NIST AI 600-1)

RISK	HOW PAPYRUS ADDRESSES IT
Information security (prompt injection, data exfiltration)	Tool results from MCP servers and documents are labeled as untrusted external content; agent code has no network; outbound requests pass the egress allow-list; consequential actions need human approval.
Confabulation	Agents cite Library passages with source path, page and SHA-256; consequential outputs go through approval; goal completion is declared with a recorded summary of evidence.
Data privacy	Prompts, documents and outputs stay inside the deploying organization's environment; Beag Labs receives no deployment data.
Value chain and component integration	Models are chosen by the organization in papyrus.yaml; dependencies are inventoried in SBOMs; the release image is signed with build provenance.
Human-AI configuration	Signed agent revisions, optional independent sign-off, approval gates and per-agent limits keep a person accountable for what each agent may do.